Audit et sécurisation d'une application vulnérable : OWASP Juice Shop

Objectif principal

Détection, exploitation et correction des vulnérabilités web dans un environnement contrôlé et réaliste (Juice Shop).

Phase 1 – Découverte et installation

- Déployer Juice Shop en local.
- Explorer l'interface et identifier les fonctionnalités principales.

Phase 2 – Audit de sécurité

- Réaliser un scan automatisé avec un outil comme OWASP ZAP (ou Burp Suite).
- Identifier au moins 5 vulnérabilités critiques (ex. injection SQL, XSS, CSRF…).

Phase 3 – Exploitation contrôlée

- Documenter l'exploitation de chaque vulnérabilité (preuve de concept).
- Expliquer les risques associés pour un utilisateur ou une entreprise.

Phase 4 – Remédiation

- Proposer des correctifs techniques (ou organisationnels).
- Comparer les solutions possibles (ex. validation côté serveur vs côté client).

Phase 5 – Rapport final

Structurer un rapport d'audit avec :

- Introduction au Juice Shop et à OWASP.
- Liste des vulnérabilités trouvées.
- Détails des exploitations.
- Solutions proposées.
- Conclusion sur l'importance de la sécurité applicative.

Livrables attendus

- Rapport écrit.
- Présentation orale avec schémas visuels.
- Démonstration pratique (exploitation d'une vulnérabilité + correctif).